

TASK 2 — SECURITY AWARENESS

Phishing Awareness Training

A comprehensive guide to recognising, understanding, and defending against modern phishing threats in the workplace and beyond.

PREPARED BY	PROGRAM	VERSION
Asad	CS Internship	2.0 — 2025



91% of all cyberattacks begin with a phishing email. This training equips you with the knowledge to stop them before they start.

INDEX

Table of Contents

This module covers phishing from first principles to advanced prevention. Each section builds on the last — read cover-to-cover or jump to what you need.

01 What is Phishing? Definition, delivery channels, and global impact statistics	02 Types of Phishing Email, Spear, Smishing, Vishing, Clone & Whaling attacks
03 How Attacks Work The 5-stage attack chain from lure creation to data theft	04 Red Flags & Warning Signs Visual indicators, suspicious URLs, and sender analysis
05 Social Engineering Psychological triggers attackers exploit to manipulate victims	06 Real-World Case Study \$100M+ BEC fraud against major tech companies — timeline & lessons
07 Prevention & Best Practices MFA, email hygiene, URL inspection, and incident response	08 Interactive Quiz 5 scenario-based questions to test your awareness — with answers
09 Key Takeaways Summary principles and action items to take away	

FOUNDATIONS

What is Phishing?

Understanding the threat is the first step to defeating it. Phishing exploits the most vulnerable part of any security system: human psychology.

CORE DEFINITION

Phishing is a social engineering cyberattack in which adversaries **impersonate trusted entities** — banks, colleagues, government bodies, or technology platforms — to deceive targets into divulging sensitive information, transferring funds, or installing malware.

91%

of successful data breaches start with a phishing email

3.4B

phishing emails sent globally every single day

\$4.9M

average cost per data breach involving phishing (2024)

COMMON DELIVERY CHANNELS



Email Phishing

The most prevalent form. Attackers craft convincing emails masquerading as legitimate organisations to steal credentials or deliver malware via attachments.



Smishing (SMS)

Text message attacks. Often impersonate delivery companies, banks, or government bodies with short, urgent messages and malicious links.



Vishing (Voice)

Phone-based attacks. Attackers impersonate IT support, financial institutions, or tax authorities to extract sensitive information verbally.



Social Media

Fake profiles, direct messages, or compromised accounts used to distribute malicious links or conduct reconnaissance for targeted attacks.

THREAT TAXONOMY

Types of Phishing Attacks

Phishing is not one-size-fits-all. Understanding each variant helps you recognise attacks regardless of how they arrive.



Email Phishing

HIGH**MOST COMMON**

Mass, untargeted campaigns sent to thousands of recipients. Attackers cast a wide net hoping a small percentage will interact with fraudulent emails pretending to be PayPal, Amazon, Microsoft, or banks. Success relies on volume, not precision.



Spear Phishing

CRITICAL**TARGETED**

Highly personalised attacks against specific individuals. Attackers research their target on LinkedIn, social media, and company websites. Messages reference real names, job titles, projects, or colleagues to appear completely legitimate.



Smishing

MEDIUM**SMS-BASED**

Phishing over SMS. A growing attack vector as users trust text messages more than email. Common lures include fake parcel delivery alerts, bank fraud warnings, and prize notifications containing malicious shortened URLs.



Vishing

MEDIUM**VOICE CALL**

Phone-based social engineering. Modern vishing increasingly uses AI voice cloning to impersonate known individuals. Attackers pose as IT helpdesks, HMRC / IRS agents, or company executives to extract credentials or authorise transfers.



Clone Phishing

HIGH**EMAIL CLONE**

A real, previously delivered email is cloned and re-sent with malicious attachments or links substituted for legitimate ones. The "resend" framing ("Here's the updated version") makes it exceptionally deceptive.



Whaling (CEO Fraud)

CRITICAL**EXECUTIVE TARGETING**

Spear phishing aimed at senior executives (CEOs, CFOs, board members). The goal is typically to authorise large wire transfers or gain access to strategic business data. Average loss per incident exceeds \$1 million.

ATTACK ANATOMY

The Phishing Attack Chain

Every phishing attack follows a predictable five-stage lifecycle. Disrupting any stage breaks the chain and protects the target.

1

STAGE 1 — RECONNAISSANCE & SETUP

Attacker Researches the Target

The attacker gathers intelligence: LinkedIn profiles, company websites, social media, breach databases. For spear phishing, they identify the target's role, manager's name, current projects, and email patterns. Infrastructure is then set up — fake domains, spoofed email addresses, and cloned websites.

2

STAGE 2 — LURE DELIVERY

Phishing Message is Sent

The crafted message — email, SMS, voice call, or direct message — is delivered to the victim. It's designed to appear as a trusted source and contain a compelling reason to act: a security alert, invoice, delivery notification, or urgent request from leadership.

3

STAGE 3 — VICTIM INTERACTION

Target Clicks the Link or Opens Attachment

The victim, believing the message to be legitimate, clicks a malicious link leading to a credential-harvesting site, or opens an attachment that executes malware. The interaction happens in seconds. Some payloads execute without any user action via drive-by downloads.

4

STAGE 4 — DATA CAPTURE

Credentials or Data are Stolen

On the fake site, the victim enters credentials, payment details, or other sensitive data. Alternatively, malware installed in the previous step begins keylogging, screenshotting, or exfiltrating files. Credentials may be immediately tested against other services (credential stuffing).

5

STAGE 5 — EXPLOITATION

Attacker Exploits Stolen Access

Stolen credentials are used to access accounts, initiate fraudulent transfers, conduct lateral movement within corporate networks, or sold on dark web marketplaces. In business email compromise (BEC), attackers may linger undetected for months before striking.

DETECTION

Warning Signs to Watch For

Train your eye to spot these signals. In a genuine phishing attempt, you will rarely see just one — they cluster together.



Suspicious Sender Address

The display name may say "PayPal Support" but the actual email address is `noreply@paypal-secure.ru` — always inspect the full address.



Artificial Urgency

Phrases like "Your account will be terminated in 24 hours" or "Immediate action required" are pressure tactics designed to override your critical thinking.



Poor Grammar & Spelling

Legitimate organisations proof-read their communications. Awkward phrasing, inconsistent capitalisation, and typos are hallmarks of poorly localised phishing kits.



Unexpected Attachments

Unsolicited files — especially `.exe .zip .docm .xlsm` — are common malware delivery vehicles. Never open files you weren't expecting.



Credential Requests

No legitimate service will ask for your password via email. Password reset flows are always initiated by the user through official channels, never by unsolicited email.



Too-Good-To-Be-True Offers

Prize notifications, lottery wins, or lucrative job offers targeting your greed. If you didn't enter a competition, you haven't won it.

⚡ URL INSPECTION — LEGITIMATE VS. FAKE

✓ REAL

<https://www.paypal.com/account/login>*Exact domain, HTTPS, no extras*

✗ FAKE

<https://www.paypal-security.com/account/login>*typosquatting + extra subdomain*

✗ FAKE

<https://paypal.account-verify.net/login>*paypal is subdomain, not the domain*

PSYCHOLOGY OF ATTACK

Psychological Triggers

Attackers are skilled manipulators who exploit fundamental human cognitive biases. Knowing which emotions they target makes you significantly harder to deceive.



Fear

Threat of account closure, legal action, or financial penalty compels victims to act without verification.



Urgency

Artificial deadlines ("within 2 hours") bypass rational decision-making and suppress the instinct to verify.



Greed

Promises of prizes, inheritance, or exclusive deals lower the victim's guard by appealing to self-interest.



Trust

Impersonating known brands, colleagues, or authorities. We naturally lower defences for familiar entities.



Curiosity

"Someone shared a file with you" or "See who viewed your profile" exploits the innate human desire to investigate.



Social Proof

"Your colleagues have already updated their credentials" uses conformity pressure to encourage compliance.

📄 REAL-WORLD LURE EXAMPLES — CAN YOU SPOT THE TRIGGER?

- › "Your Microsoft 365 licence has expired. Click here to renew immediately to avoid losing access."

[Fear + Urgency]
- › "Congratulations! You've been selected for a £500 Amazon gift card. Claim before midnight."

[Greed + Urgency]
- › "Hi, it's Sarah from IT. We're running a security audit — please confirm your credentials."

[Trust + Authority]
- › "Your parcel could not be delivered. Track it here."

[Curiosity + Trust]
- › "HMRC: You are due a tax refund of £312.50. Submit your details to claim."

[Greed + Authority]
- › "Unusual sign-in activity detected. Verify your identity now to secure your account."

[Fear + Urgency]

INCIDENT ANALYSIS

The \$100M BEC Attack

Between 2013 and 2015, a sophisticated Business Email Compromise campaign defrauded two of the world's largest technology companies of over \$100 million through phishing alone.

 CASE FILE — CLASSIFIED INCIDENT

Facebook & Google BEC Fraud

Perpetrator: Evaldas Rimasauskas · Lithuania · 2013–2015

\$100M+

Total funds transferred to attacker-controlled accounts

2 yrs

Duration before the fraud was discovered and reported

5 yrs

Prison sentence handed to the perpetrator in 2019

- PHASE 1 — RECONNAISSANCE**

Rimasauskas identified that both Facebook and Google used Taiwanese manufacturer Quanta Computer as a supplier. He registered a fraudulent company with the same name in Latvia.
- PHASE 2 — IMPERSONATION**

Forged invoices, contracts, and letters bearing executive signatures were emailed to accounting staff at both companies, requesting payment for legitimate-looking hardware and service contracts.
- PHASE 3 — FUNDS TRANSFER**

Employees transferred tens of millions to attacker-controlled bank accounts across Latvia, Cyprus, Slovakia, Lithuania, Hungary, and Hong Kong. No technical hacking was involved — only deception.
- PHASE 4 — DISCOVERY & RECOVERY**

The fraud was eventually uncovered. Both companies cooperated with the US Department of Justice. Most funds were recovered, but the reputational damage was significant. Rimasauskas was arrested in 2017.

 Key Lesson: No Organisation is Too Large or Too Sophisticated

This attack used no malware, no exploits, and no technical vulnerabilities. It succeeded entirely through social engineering and forged documents. The lesson: verification procedures for financial transactions must be robust and multi-channel, regardless of how legitimate a request appears. Always verify out-of-band (call the known number, not one provided in the email).

DEFENCE STRATEGY

Prevention Best Practices

No single control defeats phishing. An effective defence is layered — combining technical controls, verified procedures, and trained human instinct.



Verify Before You Act

- ✓ Hover over links to preview the actual URL destination
- ✓ Check the sender's full email address, not just the display name
- ✓ For financial requests, call the requester using a known phone number
- ✓ When in doubt, navigate directly to the website rather than clicking links



Technical Controls

- ✓ Enable Multi-Factor Authentication on all accounts
- ✓ Use a password manager — unique, complex passwords per service
- ✓ Keep all software, browsers, and OS fully updated
- ✓ Use email security tools with phishing filters enabled



Secure Work Habits

- ✓ Never share passwords or OTP codes — not even with IT support
- ✓ Treat unexpected attachments as suspicious by default
- ✓ Report suspicious messages to your security team immediately
- ✓ Follow your organisation's incident response procedures



Continuous Awareness

- ✓ Participate in phishing simulation exercises regularly
- ✓ Stay updated on emerging attack techniques and lures
- ✓ Share threat intelligence with colleagues across the team
- ✓ Cultivate a "verify first" culture — never shame cautious behaviour



Multi-Factor Authentication (MFA)

MFA is your single most effective defence against stolen credentials. Even if an attacker captures your username and password, they cannot access your account without the second factor. Prefer authenticator apps or hardware keys over SMS-based MFA, which is vulnerable to SIM-swapping attacks.

99.9%
of credential attacks
blocked by MFA



Interactive Knowledge Check

5 scenario-based questions · Green = correct answer · Blue = explanation

1 You receive an email from "security@g00gle.com" saying your account has been compromised. It asks you to click a link and verify your password. What should you do?

☐ A Click the link and enter credentials

☐ B Reply asking for more information

☒ C Navigate directly to google.com and check security alerts

☐ D Forward it to colleagues to confirm

💡 The domain "g00gle.com" uses zeros instead of the letter 'o' — a classic typosquatting technique. Always navigate directly to official websites. Legitimate security alerts will appear in your account dashboard.

2 Your CEO sends you an urgent email requesting a £15,000 bank transfer to a new supplier. The email says to keep it confidential and act before end of day. What is this?

☐ A A standard business transaction

☐ B A smishing attempt

☒ C A Business Email Compromise (BEC) / Whaling attack

☐ D A phishing attempt

💡 Urgency + secrecy + financial transfer = classic BEC / CEO fraud pattern. Always verify unusual financial requests through a separate, verified phone call — never via reply to the same email thread.

3 You receive a text: "Royal Mail: Your parcel is awaiting delivery. Pay £2.99 redelivery fee here: bit.ly/xH93k". What should you do?

☐ A Pay the fee — £2.99 is not worth worrying about

☒ B Go directly to the Royal Mail website to check for parcels

☐ C Click the link to verify if it's legitimate

☐ D Call the number in the text

💡 This is a smishing attack. Shortened URLs hide the true destination. Legitimate delivery companies never request payment via unsolicited text. Always go directly to the official website.

4 A website URL reads: <https://paypal.account-secure-login.net/verify>. Is this PayPal's official website?

☐ A ~~Yes — it has "paypal" in the URL~~

☐ B ~~Yes — it uses HTTPS so it's secure~~

☒ C **No — the real domain is "account-secure-login.net", not paypal.com**

☐ D ~~Impossible to tell without visiting~~

💡 The actual domain is always the last part before the first single slash. Here, "paypal" is a subdomain of "account-secure-login.net". HTTPS only means the connection is encrypted — not that the site is trustworthy.

5 Which single security measure provides the strongest protection against credential theft from phishing?

☐ A ~~A strong, complex password~~

☒ B **Multi-Factor Authentication (MFA)**

☐ C ~~An up-to-date antivirus~~

☐ D ~~Using only HTTPS websites~~

💡 MFA blocks 99.9% of account compromise attempts even when credentials are stolen. A strong password alone provides zero protection once it is captured via a phishing page. MFA is your most impactful single defensive action.

SUMMARY

Key Takeaways

You are the last line of defence. These principles, applied consistently, will protect you and your organisation from the vast majority of phishing attacks.



Awareness is Your Primary Defence

No technical control substitutes for a trained human. Attackers evolve; your instinct to pause, verify, and question must evolve with them. Scepticism is a security tool.



Verify Out-of-Band

For any request involving money, credentials, or sensitive data — verify via a separate channel. Call the known number. Never trust contact details provided in the suspicious message itself.



Report, Don't Delete

If you receive a phishing message, report it to your security team before deleting it. Your report helps protect every other colleague in your organisation from the same campaign.



Always Inspect Before You Click

Hover links, read full sender addresses, and verify the actual domain. One second of inspection can prevent months of incident response. Type URLs directly when in doubt.



Enable MFA Everywhere

Multi-Factor Authentication is the single most effective control against credential theft. Enable it on every account that supports it — work email, banking, personal accounts, social media.



Pause When Pressured

Urgency is a manipulation technique. Any message that demands immediate action and discourages verification is almost certainly an attack. Legitimate requests can always wait for a verification call.



Think Before You Click

In cybersecurity, the most powerful defensive tool is not software — it is an informed, alert, and sceptical human being. Your awareness directly protects your colleagues, your organisation, and yourself.

Asad

Cybersecurity Intern · CodeAlpha · Task 2 — Phishing Awareness Training

CodeAlpha